

Medical device software is not immune to failure

Protecting the patient's health, security and their personal data is critical

LILY HAY NEWMAN SECURITY MAR 8, 2022 12:01 AM

Critical Bugs Expose Hundreds of Thousands of Medical Devices and ATMs

The so-called Access:7 vulnerabilities are the latest high-profile IoT security fumble.



PHOTOGRAPH: FROGGYFROGG/GETTY IMAGES

<https://www.wired.com/story/access7-iot-vulnerabilities-medical-devices-atms/>

St. Jude Patches Additional Cardiac Device



2 minute read

Author:
Tom Spring
February 7, 2017
/ 1:15 pm



St. Jude Medical added another Merlin@home Transmitter medical device to its list of equipment vulnerable to a man-in-the-middle attack.

<https://threatpost.com/st-jude-patches-additional-cardiac-device/123596/>

THE SWITCH

Yes, terrorists could have hacked Dick Cheney's heart



Dick Cheney currently has a pulse – which was not always the case. (AP Photo/Olivia Harris, Pool, File)



By Andrea Peterson

October 21, 2013 at 8:58 a.m. EDT

<https://www.washingtonpost.com/news/the-switch/wp/2013/10/21/yes-terrorists-could-have-hacked-dick-cheney-heart/>

HEALTH · FORTUNE 500

Johnson & Johnson Warns Patients of an Insulin Pump Cyber Bug

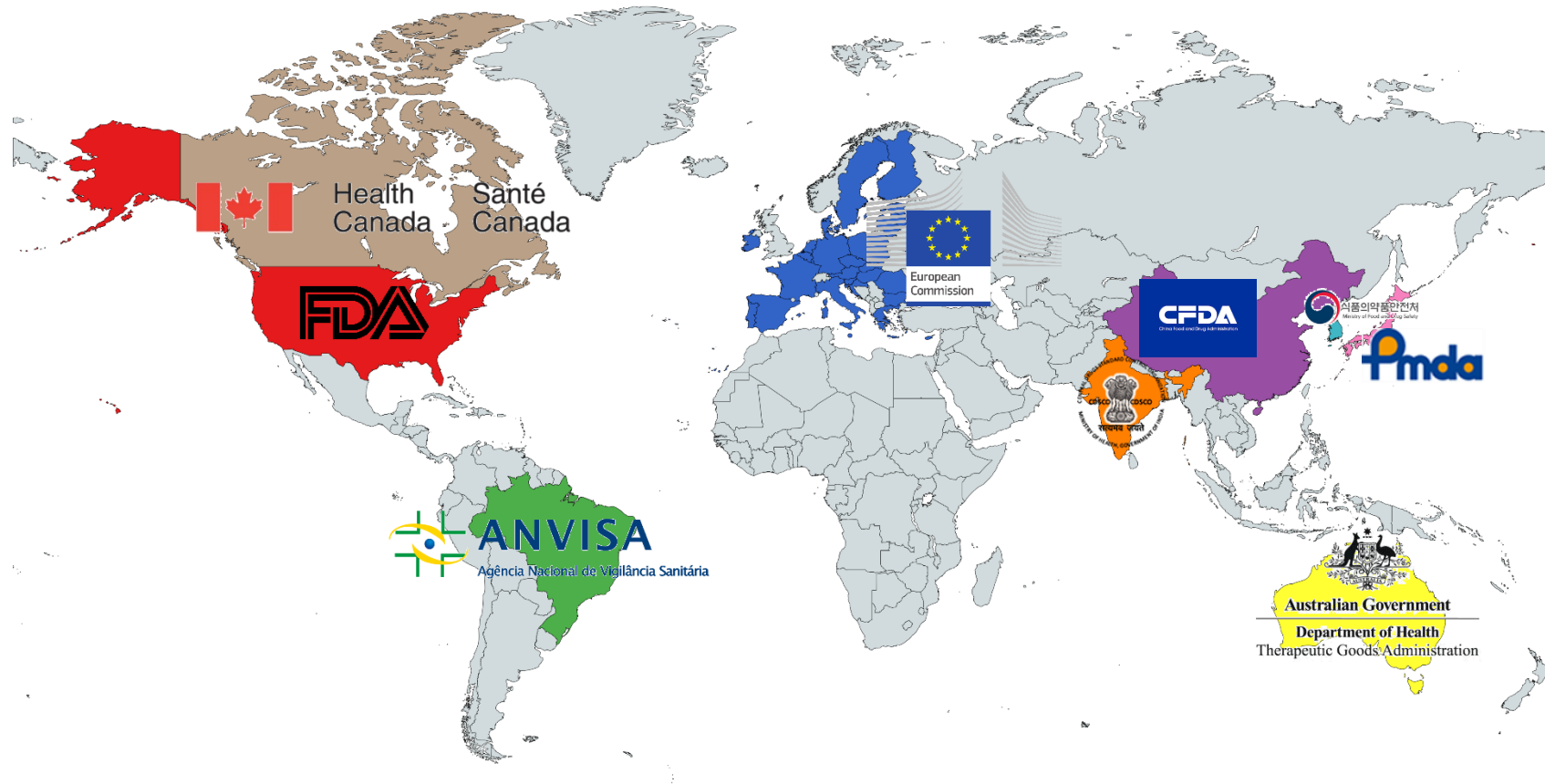
BY REUTERS

October 4, 2016 at 12:30 PM GMT+1



<https://fortune.com/2016/10/04/johnson-johnson-insulin-pump-cyber-bug/>

Medical device regulations around the world



What is the EU MDR 2017/745?

- Ensures **high standards of safety and quality** for medical devices that are:
 - produced in EU countries, or
 - supplied to EU countries
- Regulation released in 2017 by the European Parliament and the Council of the EU
- Has been in effect since 26 May 2021
- Replaces the old Medical Device Directive (from 1993!)
- Identifies what are medical devices
- Standardises data and technological advances through EUDAMED
- The certification of a medical device results in a CE mark



What is a medical device, according to the EU MDR?

Medical purposes

- Diagnosis
- Prevention
- Monitoring
- Prediction
- Treatment
- Relief
- Compensation

of a disease, lesion
or disability

- Investigation
- Substitution
- Modification

of a person's
anatomy,
physiological or
pathological
process

- Birth control and support



How to classify a medical device

Class I				Class II		Class III
Non-invasive and non-implantable devices (w/ exceptions)				Active and invasive devices		Active and implantable devices intended for long-term use.
Class I	Class Im	Class Ir	Class Is	Class IIa	Class IIb	
Any other device that does not fit in any other subclass	Devices with a measuring function Example: thermometers.	Reusable devices and invasive surgical equipment of transient use Example: scalpels.	Sterile devices Example: colostomy bags.	Intended for short-term use. Examples: tooth implants, tracheotomy tubes, syringes, X-ray devices.	Intended for long-term use. Examples: implantable birth control, blood bags.	Examples: pacemakers, breast implants, spinal disc implants, drug-coated stents.



Common standards used for Medical Device Development

Applicable Standards

- **General standards** (common to every medical device)
 - **ISO 13485:2016:** Quality Management System for medical devices industry
 - **ISO 14971:2019:** Risk Management for medical devices

- **Standards applicable to software**
 - **IEC 62304:2006:** Software lifecycle for medical devices

Quality Management System

ISO 13485:2016

- According to the MDR, the QMS:
 - shall cover *all parts and elements of a manufacturer's organisation dealing with the quality of processes, procedures and devices*
 - shall govern the *structure, responsibilities, procedures, processes and management resources* required to implement the principles and actions necessary to achieve compliance

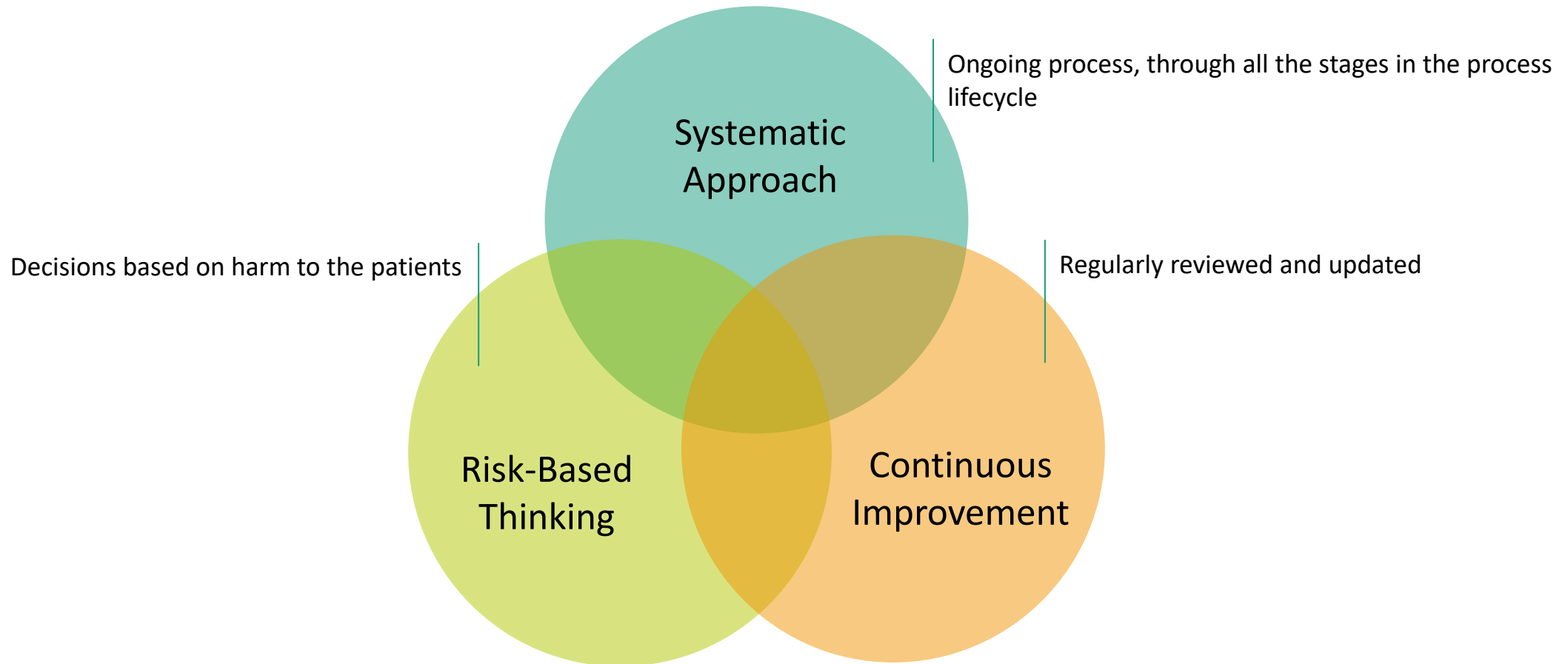
Cited from: REGULATION (EU) 2017/ 745, Article 10(8)



Source: <https://www.orielstat.com/blog/medical-device-qms-overview/>

Risk Management

ISO 14971:2019: Key principles



Risk Management

ISO 14971:2019 – Steps involved



Risk Management

ISO 14971:2019 – Risk calculation matrix

Acceptability Boundary

SEVERITY

LIKELIHOOD

	NEGLIGIBLE	MINOR	MODERATE	MAJOR	SEVERE
VERY UNLIKELY	LOW	LOW	LOW	MEDIUM	HIGH
UNLIKELY	LOW	LOW	MEDIUM	MEDIUM	HIGH
POSSIBLE	LOW	MEDIUM	MEDIUM	MEDIUM	HIGH
LIKELY	LOW	MEDIUM	MEDIUM	HIGH	HIGH
VERY LIKELY	LOW	MEDIUM	HIGH	HIGH	HIGH

Risk Management

ISO 14971:2019 – What does a “risk” look like?

- **Hazard:** Clinician enters a medication dosage for the patient that is too high
- **Cause:** Clinician is distracted or enters a typo
- **Harm:** The patient takes a medication with a dosage that is too high and causes a seizure

Likelihood: Unlikely

Severity: Moderate

- **Resulting risk level:** MEDIUM



- **Mitigation measure:** Implement a functionality that validates entered dosages relative to reference levels and the patient's information

Residual likelihood: Very

Unlikely

Residual severity: Moderate

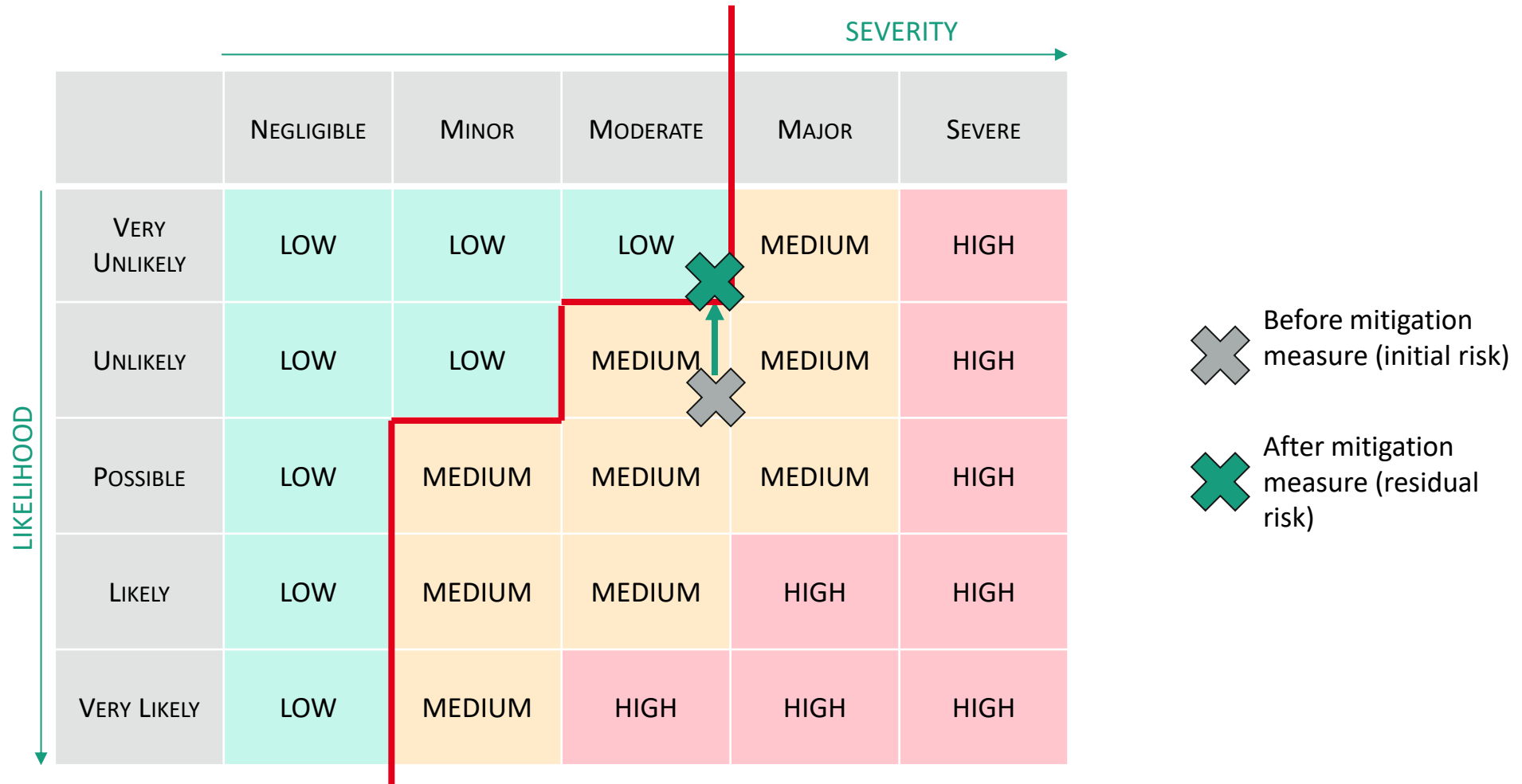


- **Residual risk level:** LOW

- This risk level is acceptable.

Risk Management

ISO 14971:2019 – What does a “risk” look like?

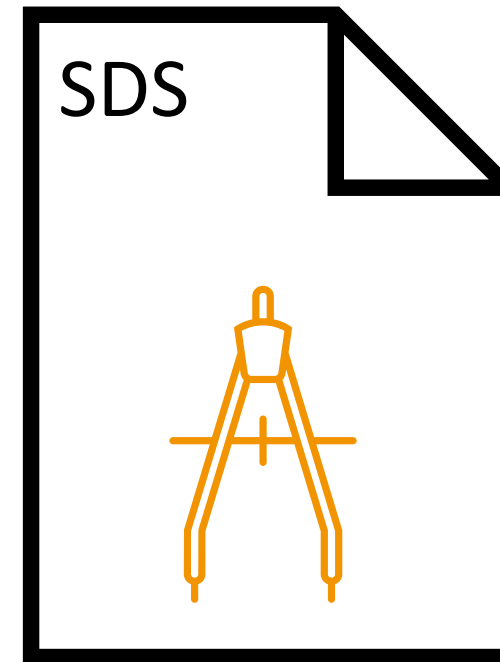


■ Base documents



■ Software Requirements Specification (SRS)

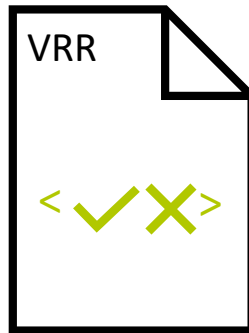
- Device's intended use and users
- List of functional, non-functional, regulatory and other requirements



■ Software Design Specification (SDS)

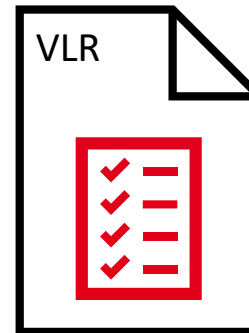
- Description of components
- Architecture (UML diagrams, ...)
- Resource usage
- Off the shelf/third party software usage

■ Evidence documents



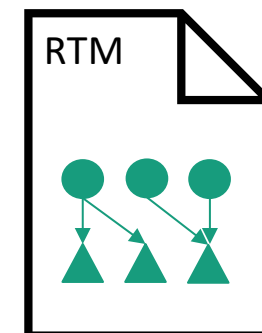
■ Verification Report

- Static analysis/Linter report
- Unit test results



■ Validation Report

- Functional test results (either manual or automated)

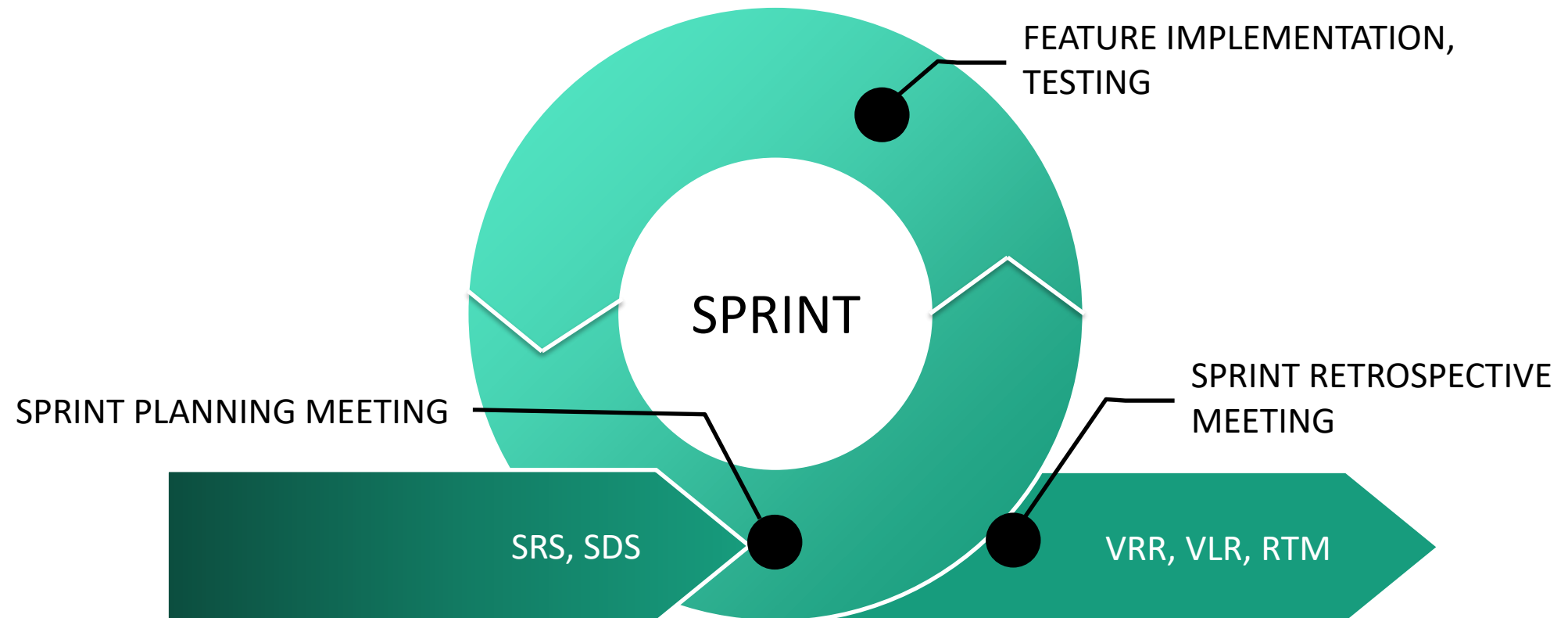


■ Req. Traceability Matrix

- Connects tests with the SRS
- Ensures requirements are covered and tested

Software Lifecycle

IEC 62304:2006 – How to integrate it into an Agile development methodology



General Data Protection Regulation (GDPR)

Overview



Purpose: Protects the personal data and privacy of EU citizens, applying to any organization that processes their data, globally.



Key Principles: Lawfulness, Fairness & Transparency; Data Minimization; Purpose Limitation; Accuracy; Security; Storage Limitation.



Data Subject Rights: Access, Rectification, Erasure (Right to be Forgotten), Portability, Object, Restrict.

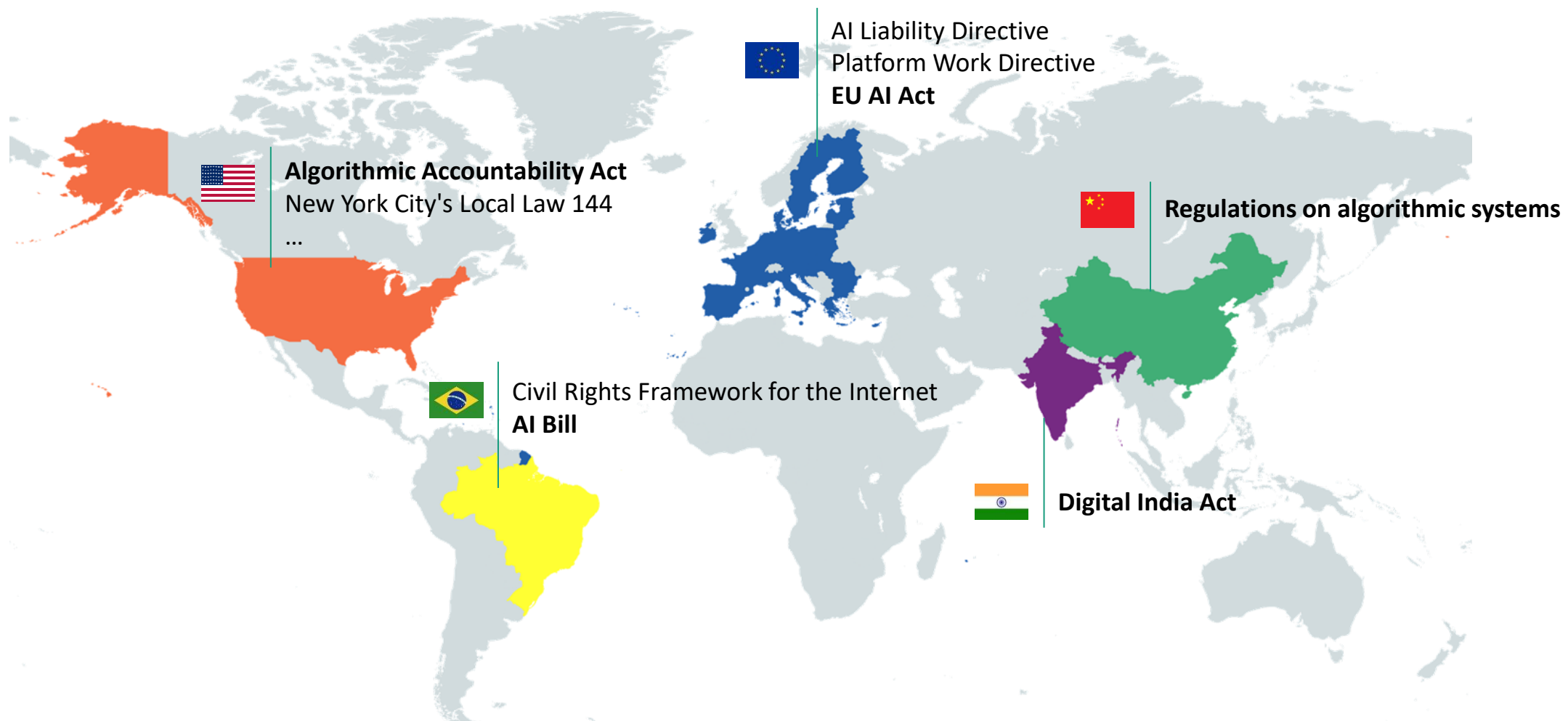


Breach Reporting: Notify authorities within 72 hours of a data breach.



Accountability: Keep detailed records and ensure compliance via **Data Protection Impact Assessments (DPIAs)** and **Data Processing Agreements (DPAs)** with third parties.

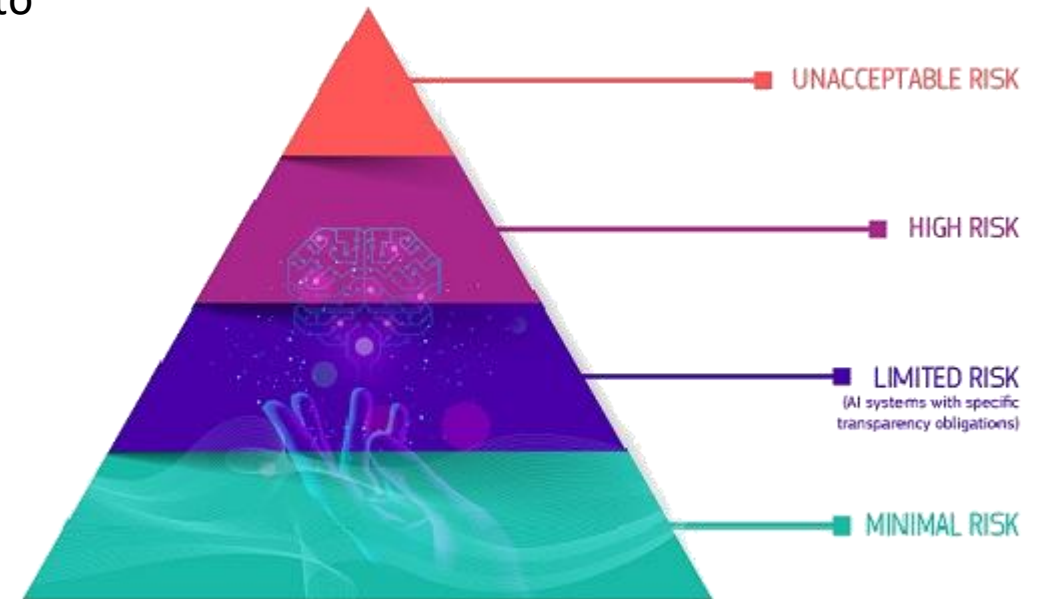
Global Regulatory Landscape for AI



EU AI Act

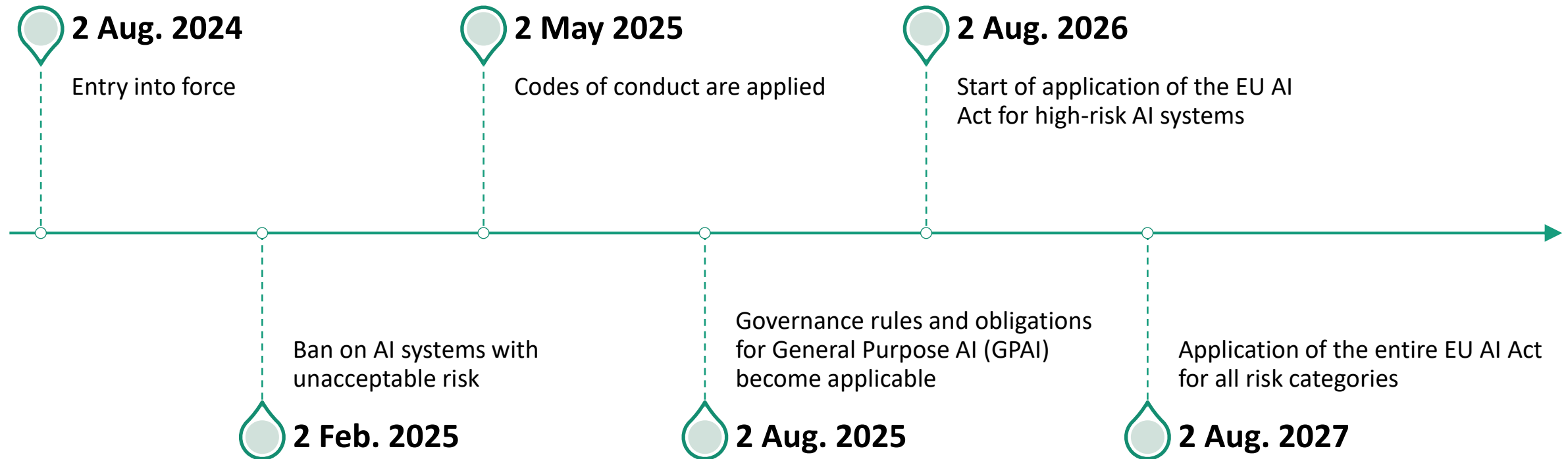
Overview

- The AI Act is a regulation proposed by the European Union to govern the development, deployment, and use of AI systems.
- It establishes a risk-based framework, classifying AI systems into four categories based on their potential risks to safety and fundamental rights:
 - **Unacceptable risk:** Banned (ex: AI for social scoring or manipulation).
 - **High risk:** Heavily regulated (ex: **AI in healthcare**, law enforcement, employment).
 - **Limited risk:** Subject to transparency requirements (ex: AI chatbots).
 - **Minimal risk:** No specific regulations (ex: spam filters).



EU AI Act

Timeline



AI Act

Requirements for High-Risk Systems

- AI systems in healthcare (ex. diagnostic tools, medical imaging analysis) are classified as high-risk due to their direct impact on patient safety.
- Key Requirements for High-Risk AI Systems:
 - **Data Quality:** Must ensure that training data is accurate, reliable, and unbiased.
 - **Transparency:** Systems must be explainable to users (ex, doctors, patients) with clear documentation of AI decision-making processes.
 - **Human Oversight:** AI must work alongside human professionals, providing assistive functions rather than fully autonomous decision-making.
 - **Conformity Assessments:** AI systems must undergo assessments before being deployed to ensure they meet safety and performance standards.

Artificial Intelligence Standards

Key Organizations Producing AI Standards

- **ISO/IEC JTC 1/SC 42 (Global):** Global AI standards on trust, bias, and transparency.
- **ITU (Global):** Ethics and safety in global AI applications.
- **ETSI (EU):** AI in telecom (5G, cybersecurity) in Europe.
- **NIST (USA):** AI risk management, fairness, and reliability.
- **CEN/CENELEC (EU):** AI in medical devices, robotics.

25 standard producers

311 published standards

43 in draft/pre-draft stage

Useful resource: <https://aistandardshub.org/>

Artificial Intelligence Standards

Most relevant AI Standards

■ ISO/IEC 5338:2023 - AI System Lifecycle Processes

- Covers processes across the full lifecycle: design, development, testing, deployment, operation and maintenance
- Addresses the potential for:
 - performance degradation over time;
 - the autonomous nature of the systems;
 - the heavy reliance on data;
 - the need for continuous monitoring;
 - The need to retrain and update the system over time as its environment evolves.

Artificial Intelligence Standards

Most relevant AI Standards

- **ISO/IEC 23894:2023 - Guidance on Risk Management for AI**
 - Guidance on managing the unique risks that can arise with AI systems
 - It highlights **AI-specific risk sources** and **failure modes** that we need to consider:
 - lack of explainability;
 - unreliable performance in complex environments;
 - inherent biases and privacy issues from training data.
 - To **manage risks**, include **impact assessments**, **human oversight**, **continuous monitoring**, and ensure **high data quality**

Artificial Intelligence Standards

Most relevant AI Standards

■ ISO/IEC 42001:2022 - AI Management System

- **Goal:** Responsible use and development of AI systems
- Outlines requirements for:
 - **Policies and principles** on the **use of AI**;
 - Processes to **identify and manage AI risks**;
 - Assignment of **roles and responsibilities**;
 - Maintaining **documentation**;
 - Monitoring **performance**.

Compliance with standards and regulations

Actions for developers

STEP 1: Integrate Compliance into the AI Development Workflow

- **Action:** Integrate compliance checks early in the development lifecycle by building a compliance-by-design approach.
- **How:**
 - Identify and document potential risks such as **bias, transparency issues, and model security vulnerabilities** early in the process.
 - Implement data drift and concept drift detection to **track changes in model behavior** over time (ex. **WhyLabs**).
 - Ensure **fairness** in data and models, by using tools like **Fairness Indicators** or **IBM AI Fairness 360**.
 - Maintain a **versioned record of datasets** (ex. **DVC**) and **models** (ex. **MLflow**) to ensure traceability for audits.
 - **Conformity Assessment:** Prepare documentation including risk assessments reports, model test results and compliance reports, aligning with the **AI Act** and **MDR**.

Related Standards/Regulations: ISO/IEC 23894:2023, ISO/IEC 42001:2023, AI Act, MDR

Compliance with standards and regulations

Actions for developers

STEP 2 : Implement Data Privacy Mechanisms in Your Code

- **Action:** Incorporate data minimization, encryption, and pseudonymization practices within your system's architecture.
- **How:**
 - Implement data minimization to **limit exposure to sensitive data** through techniques like differential privacy.
 - Apply **encryption for data** at rest and in transit.
 - Develop APIs that **manage user consent and deletion requests**, ensuring compliance with GDPR's right to be forgotten and **AI Act** transparency requirements.
 - **Data Breach Reporting:** Set up alerts to **ensure quick detection and reporting** of any data breaches within 72 hours.

Related Standards/Regulations: GDPR, ISO/IEC 42001:2023, AI Act

Compliance with standards and regulations

Actions for developers

STEP 3 : Model Explainability and Accountability

- **Action:** Ensure that AI models are explainable and accountable, especially for high-risk applications.
- **How:**
 - Implement methods to **explain model decisions**, making results understandable for users and regulators.
 - Use **LIME** or **SHAP** for generating explanations of complex model predictions
 - Develop user interfaces using **Streamlit** that allow users to query model decisions
 - **Log each model prediction and the data inputs that influenced it** to maintain transparency (ex. **MLflow**).
 - **Human Oversight:** Provide an **interface for human operators** to review and override AI decisions as needed.

Related Standards/Regulations: ISO/IEC 5338:2023, AI Act, MDR

Compliance with standards and regulations

Actions for developers

STEP 4 : Model Validation and Testing

- **Action:** Integrate thorough model validation into your development process.
- **How:**
 - Regularly **test models for accuracy, fairness, and safety** through unit tests, integration tests and functional tests (ex. **Deepchecks**).
 - **Clinical Evaluation (MDR):** For medical AI systems, ensure models are validated against real-world clinical data and document all evaluation results.

Related Standards/Regulations: ISO/IEC 5338:2023, AI Act, MDR

Compliance with standards and regulations

Actions for developers

STEP 5 : Ensure Post-Deployment Monitoring and Maintenance

- **Action:** Continuously monitor deployed models to ensure they perform safely and reliably.
- **How:**
 - Track model performance, detecting and responding to anomalies.
 - Set up incident logging and alerts for performance degradations or bias issues, ensuring that relevant stakeholders are notified for quick remediation (ex. **Evidently AI**).
 - Automate updates and model retraining (ex. **Seldon Core**) when performance metrics fall below acceptable levels, ensuring ongoing compliance with **MDR** surveillance requirements.
 - Log all updates and performance changes to maintain a record for **AI Act** audits and conformity assessments.

Related Standards/Regulations: ISO/IEC 42001:2023, MDR, AI Act

Compliance with standards and regulations

Actions for developers

STEP 6 : Document Everything and Build for Auditability

- **Action:** Create detailed documentation of your AI system's development and lifecycle.
- **How:**
 - Maintain clear documentation of all **data handling, model training, and testing processes**.
 - Use **model cards** to outline the purpose, performance, and ethical considerations for each model.

Related Standards/Regulations: ISO/IEC 42001:2023, MDR, AI Act

Compliance with standards and regulations

Actions for developers

STEP 7 : Integrate security measures and ethical practices into your AI systems

- **Action:** Develop and integrate security measures to protect against vulnerabilities and ensure ethical use of AI.
- **How:**
 - Secure data exchanges and model endpoints using **industry-standard encryption protocols**.
 - **Evaluate models for fairness** and ensure that models respect the diversity of user groups.
 - Implement ethical AI principles by designing systems that **allow user feedback on model performance**, especially in clinical environments under **MDR**.
 - **Document all security measures and ethical considerations** to ensure compliance with **AI Act** requirements for ethical AI use.

Related Standards/Regulations: *GDPR, AI Act, MDR*

Compliance with standards and regulations

Actions for developers

STEP 8 : Conduct Internal Audits and Prepare for Conformity Assessments

- **Action:** Regularly audit AI systems to ensure compliance and readiness for regulatory reviews.
- **How:**
 - Document the **results of audits** to ensure easy access during regulatory reviews.
 - Compile a **package of clinical evaluations, risk management reports, and post-market surveillance data**, as required by both the **MDR** and **AI Act**, for external audits and CE marking.
 - **Engage with a notified body for external reviews** of high-risk AI systems, ensuring readiness for CE marking under **MDR**

Related Standards/Regulations: ISO/IEC 42001:2023, MDR, AI Act

Compliance with standards and regulations

Actions for developers

STEP 9 : Include UDI Implementation and Traceability

- **Action:** Implement Unique Device Identification (UDI) for AI-based medical devices.
- **How:**
 - Maintain a secure **database of UDI codes**, ensuring each version of the AI model has a traceable identifier.
 - Register UDI codes with **EUDAMED** and keep a detailed **log of all model versions, including updates and changes for regulatory tracking**.
 - Use **DVC** to track changes to models associated with each UDI to ensure traceability throughout the lifecycle of the device

Related Standards/Regulations: MDR

Compliance with standards and regulations

Actions for developers

STEP 10 : Incorporate Data Subject Rights Management

- **Action:** Respect data subject rights, including access, rectification, and erasure.
- **How:**
 - Develop **APIs to handle data access and deletion requests**, ensuring user data is managed according to **GDPR** standards..
 - Log each request and **maintain records of actions** taken to comply with data privacy regulations.
 - Set up procedures to respond quickly to **data breaches**, ensuring compliance with **GDPR's** 72-hour reporting requirement.
 - Document all **interactions with data subjects** and maintain these records for audits under **GDPR** and the **AI Act**

Related Standards/Regulations: GDPR, AI Act

Conclusion

Key takeaways for developers

■ **Conformity Assessment Readiness:**

- Prepare **comprehensive documentation for audits** under the AI Act and MDR, ensuring readiness for reviews.

■ **Human Oversight Mechanisms:**

- Provide clear paths for human intervention where required, ensuring that human operators can **override AI decisions**.

■ **Data Security and Privacy:**

- Focus on **minimizing data exposure** and ensuring compliance with GDPR through **built-in privacy measures**.

■ **Clinical Evaluation:**

- **Validate AI systems in real-world environments** when used in medical applications, **maintaining safety and performance records**.